

Comment Template for: NIST SP 800-217 (Final Public Draft)

Please submit responses to piv_comments@nist.gov by January 10, 2025

Organization: CertiPath Inc.
Name of Submitter/POC:
Email Address of Submitter/POC: j

Comment #	Section	Page #	Line #	Comment (Include rationale for comment)	Suggested Change	
1	2.1.1	9	455	The statement "The primary credential for a PIV identity account is the PIV Card, which is issued to the subscriber, as defined in [FIPS201]." is misleading. The PIV Card is NOT a credential per se. It is a container that holds various credentials associated with the card and the cardholder. I believe the primary credential in this case would be the PIV Authentication PKI certificate and its associated public-private key pair.	Recommend revising this sentence to state "The primary credential for a PIV identity account is the PIV Authentication certificate, which is issued to the subscriber, as defined in [FIPS201]."	
2	2.1.2	9	477	Typographical error "bye" should be "be".	Repair typo by replacing "bye" with "be"	
3	2.2.1	10	521	"The PIV IDP is the PIV IDP. . ." I suggest this is too much use of the term "PIV IDP"	Recommend revising. Simplest is to remove second "PIV" i.e. The PIV IDP is the IDP. . ." Conversely, you could remove the entire second PIV IDP as follows "The PIV IDP is identified in a trust agreement. . ."	
4	2.2.1	10	526	Typographical error "an trust agreement" should be "a trust agreement"	Replace "an" with "a" as indicated.	
5	2.2.2	11	539	I believe "issues" is the wrong verb here. PIV identity accounts aren't "issued," they are "maintained," "managed," or perhaps "created" or "established"	Replace "issued" with a more appropriate verb.	
6		3	13	598	Recommend adding a reference to Section 3.4 after "shared signals". This is the first time the term is mentioned and it is confusing without knowing there is a Section 3.4 addressing the subject of shared signals	Add reference to Section 3.4 after "shared signals"
7		3	13	601	Was the "of" intended here? The term "purpose of use" is awkward, but not sure you intended "purpose or use"	Verify the use of "of" in this bullet. Consider revising for clarity.
8		3.2	15	666	"For all agencies covered by the federation authority's trust agreements, the federation authority SHALL indicate the agency's declared home agency IdP, if one exists ." This suggests that the establishment of a home agency IDP is optional, whereas, Section 2.2 appears to suggest it is mandatory. Recommend this be made clear. Granted, there is a statement that home agency IDP is required for all transactions FAL2 and FAL3, so an agency that only employed federations services at FAL1 could get away without establishing a home IDP, this would seem unlikely .	If home IDP is optional provided an agency does not federate beyond FAL1 - be clear about this in Section 2.2 or make establishment of a home IDP mandatory, regardless of FAL and remove "if one exists" from line 666.
9		3.3	16	702-703	"For each federated transaction with an RP, the proxy SHALL determine the <u>appropriate</u> upstream PIV IdP that is <u>appropriate</u> for each PIV identity account it proxies to a downstream RP." Too many uses of the word "appropriate".	Recommend revising this sentence as follows: "For each federated transaction with an RP, the proxy SHALL determine the <u>appropriate</u> upstream PIV IdP that is <u>appropriate</u> for each PIV identity account it proxies to a downstream RP."
10		3.3	16	707-709	"In its role as an IdP in a trust agreement, the proxy SHALL disclose to the RP the proxy's list of upstream PIV IdPs that the proxy uses as accounts for that RP within the trust agreement." Too many uses of the word "proxy" - makes it hard to read.	Recommend revising this sentence as follows: "In its role as an IdP in a trust agreement, the proxy SHALL disclose to the RP the proxy's list of upstream PIV IdPs that the proxy it uses as accounts for that RP within the trust agreement."
11		4.1	20	809-810	"The PIV IDP SHOULD be the home agency IDP for the agency if the home agency IDP is known for the target agency by the RP." Somewhat related to comment 8 above, this sentence is confusing. Not terribly sure what the "target agency" is in this context - is it synonymous with home agency?	Recommend reviewing/revising this sentence for clarity. As written, I don't understand it well enough to make a suggested change.
12	4.1.3	22	Fig. 3	Typographical error in title "Fig. 3. RP-managed noun authenticators"	Repair typo by replacing "noun" with "bound"	
13		5.2	26	946-947	"The attribute bundle SHALL indicate which FALs the subscriber-controlled wallet is authorized to act at." Awkward sentence structure.	Recommend revising as follows: "The attribute bundle SHALL indicate which FALs <u>are authorized for</u> the subscriber-controlled wallet. is authorized to act at. "
14	6.2.3	32	1153	In Section 1.2.1, it states "PIV federation deployments will need technical interoperability profiles that are suitable for the federation protocol being used. The details of such profiles are out of scope for this document, but all technical interoperability profiles will need to consider the following points." In Section 6.2.3 it states: "Each of these options has different tradeoffs and considerations, and an interoperable technical profile of this specification SHOULD define which of these are supported." The statement in Section 6.2.3 is somewhat confusing. The individual technical profiles cited in Section 1.2.1 <i>are based on</i> SP 800-217 but also outside of the document.	Recommend revising the statement in Section 6.2.3 as follows: "Each of these options has different tradeoffs and considerations, and an interoperable technical profile of based on this specification SHOULD define which of these are supported."	